INCIDENT INVESTIGATION

Cloudora Phishing Campaign Investigation

Phishing campaign and account compromise investigation

Incident ID	CLD-0002 (Priority P1)
Investigation type	Phishing Campaign and Account Compromise Investigation
Environment	Microsoft Entra ID, Azure Data Explorer, VS Code
Organization	Cloudora (fictional)
Related report	Security Incident Report CLD-IR-0002

Contents

1. Investigation Overview
2. Incident Scenario
3. Investigation Objectives
4. Evidence and Data Sources
5. Mail Analysis
6. Campaign Infrastructure Mapping
7. Threat Intelligence Enrichment
8. Campaign Scoping
9. Message Delivery Analysis
10. Click Analysis
11. Credential Submission Analysis
12. Account Compromise Investigation
13. Freya and Ryan Account Investigation
14. Impossible Travel Analysis
15. Attacker IP Pivot
16. Timeline, IOCs and MITRE Mapping
17. Containment and Eradication
18. Verification After Containment
19. Key Findings
20. Lessons Learned
21. NIST Incident Response Lifecycle Mapping
22. Investigation Methodology
23. Final Assessment

1. Investigation Overview

This investigation examines a targeted phishing campaign against Cloudora, a fictional London-based B2B HR and payroll software company with approximately 150 employees.

The campaign used a payroll-themed email designed to create urgency and convince employees to confirm their payroll information before a stated deadline.

40 employees were targeted by the campaign. Six users clicked the phishing link, and two submitted their credentials. Subsequent analysis of Microsoft Entra ID sign-in logs identified suspicious successful authentication involving credentials exposed during the campaign.

The investigation began with analysis of the raw phishing emails and was then expanded using message trace data and identity telemetry to determine the scope and impact of the incident.

The investigation followed an evidence-first approach. Email evidence was analyzed before threat intelligence was used for enrichment, followed by message trace analysis and identity investigation.

2. Incident Scenario

Cloudora employees received emails with the subjects:

```
Payroll update: action required before 5pm
Action required: confirm your August payroll details
```

The emails instructed employees to confirm their payroll details before 5:00 p.m., implying that failure to do so could result in their salary being held.

The campaign used two phishing email variants and a look-alike HR domain.

The investigation also included a legitimate Cloudora newsletter as a comparison sample.

This allowed the analysis to distinguish between:

- A clearly unauthenticated phishing message
- A phishing message that passed SPF, DKIM, and DMARC
- A legitimate Cloudora message that also passed SPF, DKIM, and DMARC

3. Investigation Objectives

The investigation aimed to:

1. Determine whether the reported emails were malicious.
2. Identify the techniques used to impersonate Cloudora.
3. Analyze sender information, authentication results, headers, domains, and URLs.
4. Identify infrastructure associated with the campaign.
5. Determine how many users received and interacted with the emails.
6. Identify users who submitted credentials.
7. Determine whether exposed credentials were subsequently used.
8. Identify suspicious authentication activity.
9. Determine whether multiple accounts were accessed from shared infrastructure.
10. Identify appropriate containment and eradication actions.
11. Verify that suspicious activity stopped following containment.
12. Document lessons learned and map the investigation to the NIST incident response lifecycle.

4. Evidence and Data Sources

Evidence	Purpose
.EML email files	Analyze message content, headers, authentication, URLs, and infrastructure
Message trace CSV	Determine delivery, clicks, and credential submission
Microsoft Entra ID sign-in logs	Investigate successful and failed authentication
KQL queries	Search and correlate investigation data
VirusTotal	Enrich domain and infrastructure information
AbuseIPDB	Enrich IP reputation information
Incident report template	Record investigation findings and response actions

The evidence sources were used together rather than independently.

The email files established what was sent. Message trace data established who received and interacted with the messages. Entra ID sign-in logs were then used to determine whether exposed credentials were subsequently used.

5. Mail Analysis

Three email samples were analyzed during the investigation: Phishing Variant A, Phishing Variant B, and a legitimate Cloudora newsletter. The messages were reviewed from their raw .EML files in VS Code to examine the headers, authentication results, sending infrastructure, and URLs without opening the messages in a mail client.

5.1 Phishing Variant A

Variant A used the subject “Payroll update: action required before 5pm” and instructed employees to confirm their payroll details before 5:00 p.m. The sample was the copy received by Freya Lynn. The message presented itself as coming from:

```
From: payroll@cloudora.io
```

However, the Reply-To address was:

```
hr-support@cloudora-hr-portal.example
```

Cloudora’s legitimate HR portal is myhr.cloudora.io, making the Reply-To domain a significant impersonation indicator.

The Received headers identified external infrastructure associated with:

```
198.18.44.10
```

A second sending IP associated with the campaign was:

```
198.18.44.23
```

Authentication results were:

SPF	DKIM	DMARC
Fail	Fail	Fail

The Authentication-Results header also showed compauth=fail, and the message action was quarantine. The combination of authentication failures, the look-alike domain, external infrastructure, and

payroll-themed credential request indicated that the message was attempting to impersonate Cloudora.

Assessment: Phishing

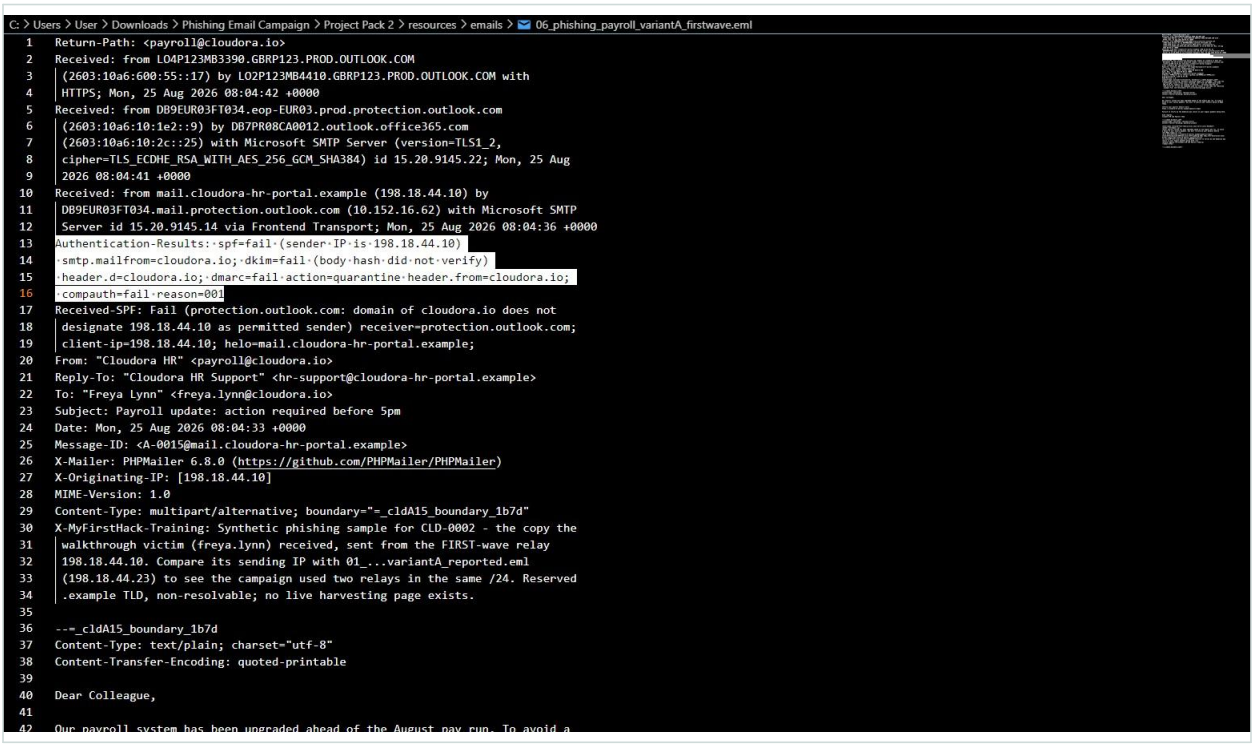


Figure 1. Variant A headers and authentication results

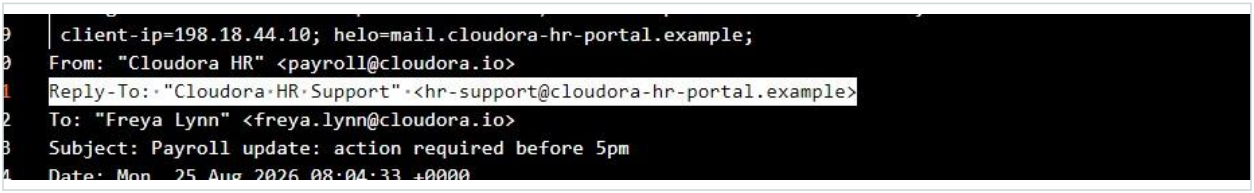


Figure 2. Variant A Reply-To pointing to the look-alike domain

5.2 Phishing Variant B

Variant B used the subject “Action required: confirm your August payroll details” and followed the same payroll-themed campaign but used different sending infrastructure:

198.18.51.7

Its From address was payroll@cloudora-hr-portal.example and its Reply-To was payroll.support@cloudora-hr-portal.example, so every address in the message pointed to the look-alike domain. Unlike Variant A, the message returned:

SPF	DKIM	DMARC
Pass	Pass	Pass

The authentication results did not make the message legitimate. The authenticated infrastructure was associated with the look-alike phishing domain rather than Cloudora’s legitimate cloudora.io environment.

This was an important finding because SPF, DKIM, and DMARC confirm authentication of a domain. They do not prove that the domain itself is trustworthy or belongs to the organization being impersonated.

The message was therefore still assessed as phishing based on its domain context, infrastructure, payroll pretext, and relationship to Variant A.

> **Assessment: Phishing**

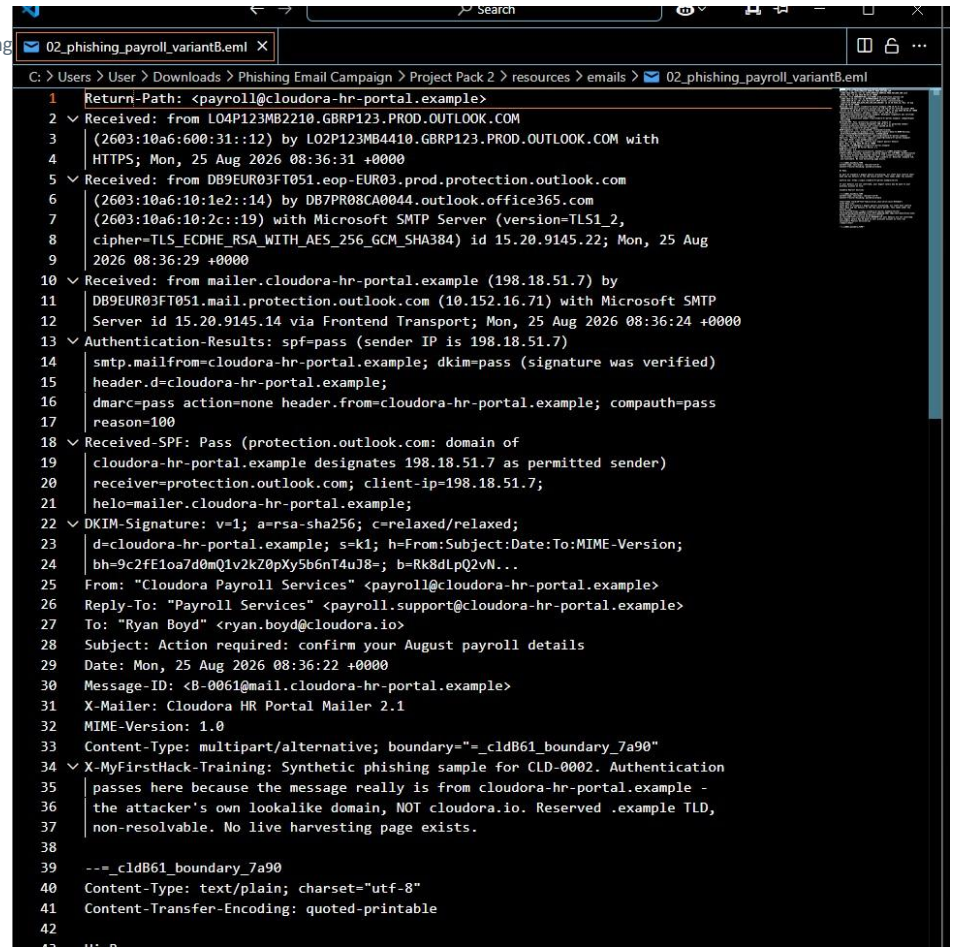


Figure 3. Variant B headers and authentication results

5.3 Legitimate Cloudora Newsletter

A legitimate Cloudora newsletter was analyzed as a comparison sample.

The message used:

`From: news@cloudora.io`

Authentication results were:

SPF	DKIM	DMARC
Pass	Pass	Pass

The DKIM signature was aligned with the legitimate cloudora.io domain. A second signature associated with mcsv.net was also present, consistent with legitimate third-party mailing infrastructure.

The message contained appropriate unsubscribe functionality and links associated with Cloudora's legitimate mailing infrastructure. No indicators linking it to the phishing campaign were identified.

> **Assessment: Legitimate**

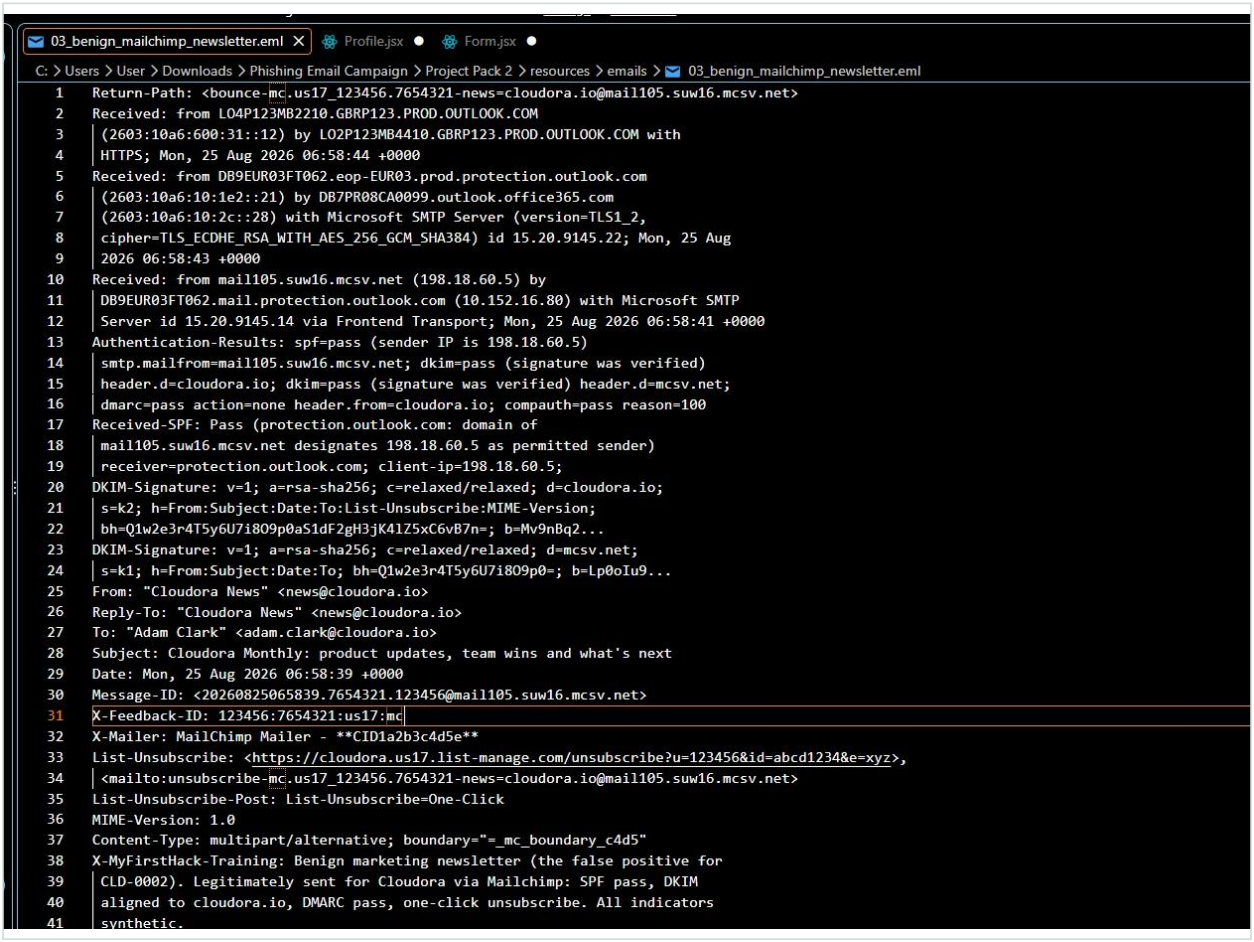


Figure 4. Legitimate newsletter headers and authentication results

5.4 Email Comparison

	Variant A	Variant B	Legitimate Newsletter
Purpose	Payroll phishing	Payroll phishing	Newsletter
SPF	Fail	Pass	Pass
DKIM	Fail	Pass	Pass
DMARC	Fail	Pass	Pass
Domain context	Look-alike	Look-alike	Legitimate cloudora.io
Infrastructure	Phishing	Phishing	Legitimate mailing infrastructure
Assessment	Phishing	Phishing	Legitimate

The comparison shows why authentication results cannot be interpreted in isolation. Variant B and the legitimate newsletter both passed SPF, DKIM, and DMARC, but only the newsletter used authentication, domain alignment, infrastructure, and message context consistent with legitimate Cloudora

communication.

The email analysis therefore established the phishing nature of the campaign and identified three sending IPs and one look-alike domain for further investigation.

6. Campaign Infrastructure Mapping

The email analysis identified the following infrastructure:

Indicator	Type	Relevance
cloudora-hr-portal.example	Domain	Look-alike phishing domain
198.18.44.10	IP	Variant A sending infrastructure
198.18.44.23	IP	Additional Variant A infrastructure
198.18.51.7	IP	Variant B sending infrastructure

The use of multiple sending IPs indicated that the campaign was not dependent on a single mail server.

The look-alike domain was particularly relevant because it was designed to resemble Cloudora's legitimate HR infrastructure.

The infrastructure identified during email analysis was later used for threat intelligence enrichment and containment.

7. Threat Intelligence Enrichment

Threat intelligence was used after the initial evidence had been established.

This followed an evidence-first, enrichment-second approach.

7.1 VirusTotal

The look-alike domain was reviewed in VirusTotal.

The investigation considered:

- Detection results
- Domain creation information
- Related infrastructure
- Associated relationships

The result showed the domain had been registered only days before the campaign and was related to the same sending IPs found in the email headers. This provided additional context around the domain and its infrastructure.

VirusTotal results were treated as supporting intelligence rather than standalone proof that the domain was malicious.

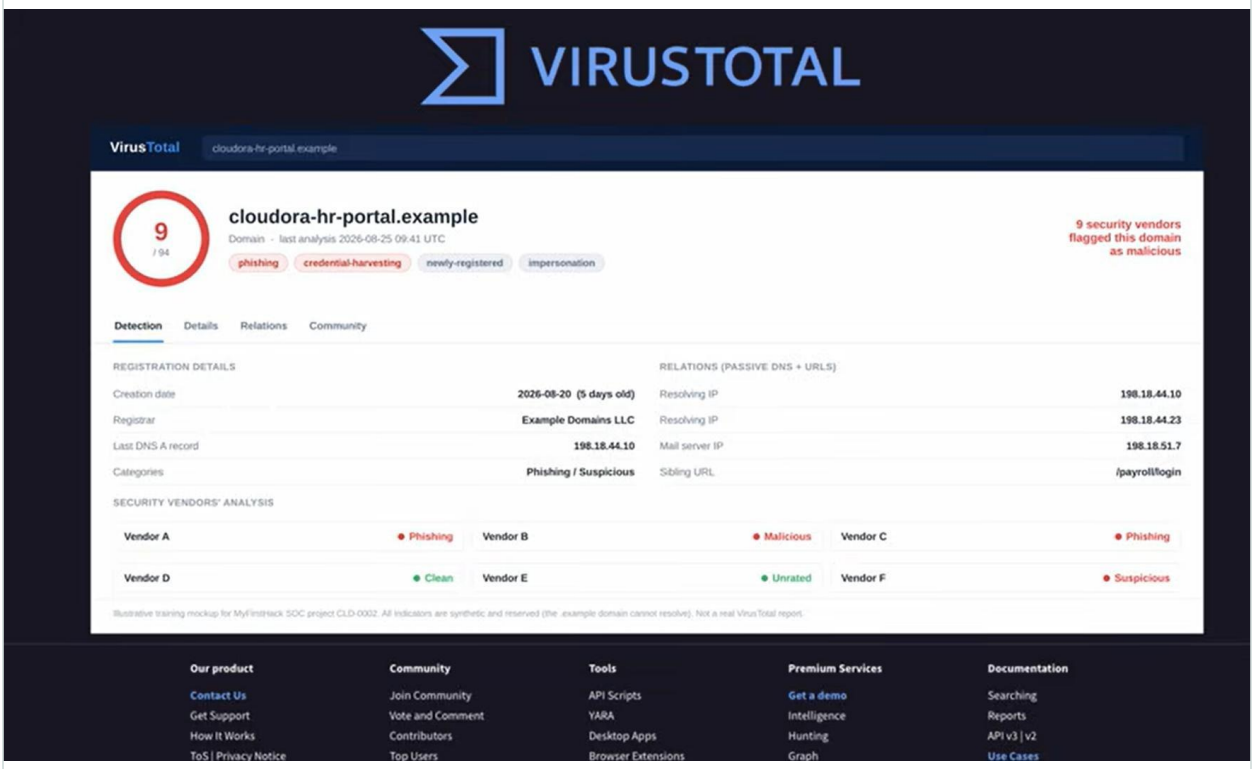


Figure 5. VirusTotal result for cloudora-hr-portal.example

The domain and IPs in this scenario are synthetic, so the VirusTotal and AbuseIPDB pages shown here are simulated.

7.2 AbuseIPDB

The identified IP infrastructure was reviewed in AbuseIPDB.

One IP, 198.18.44.10, returned an abuse confidence score of 100.

This score represents a very high abuse confidence rating within AbuseIPDB's scoring system. It should not be interpreted as a 100% probability that the IP is malicious.

The result was therefore treated as supporting intelligence alongside the email evidence and campaign activity.

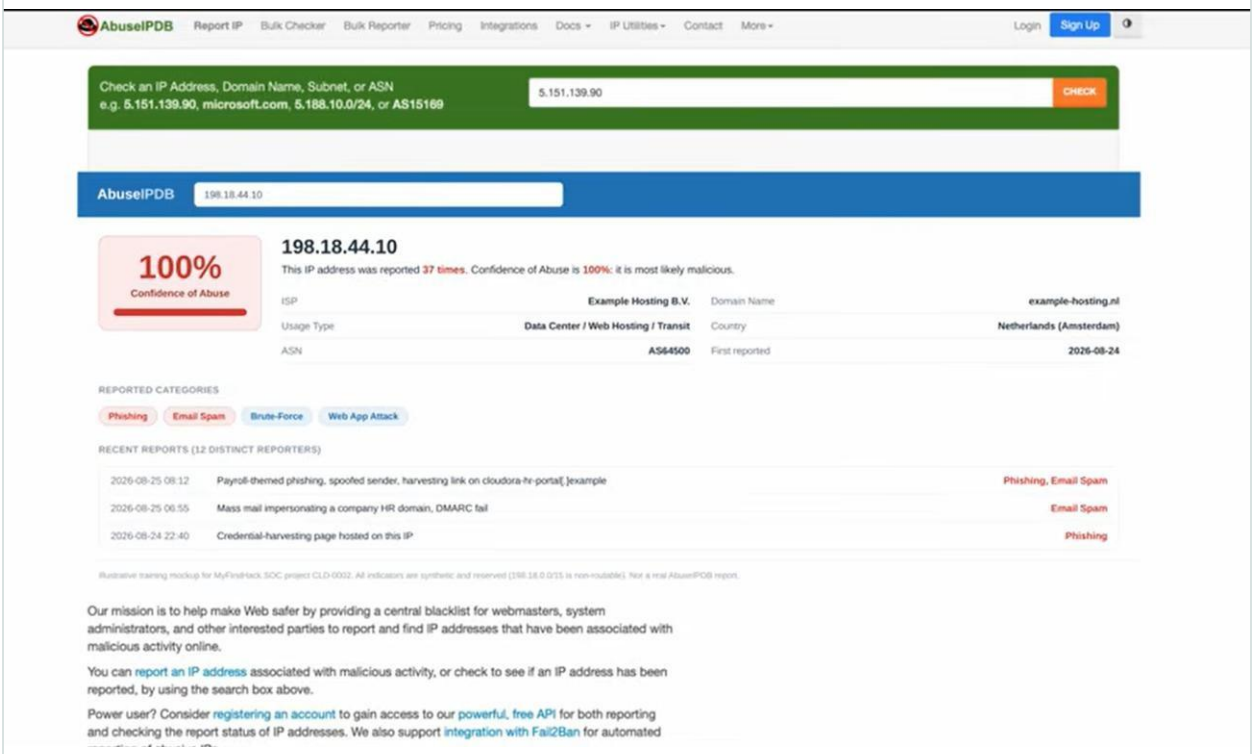


Figure 6. AbuseIPDB result for 198.18.44.10

8. Campaign Scoping

Once the email samples and infrastructure had been assessed, the investigation moved to message trace data to determine the scope of the campaign.

40 employees were targeted by the phishing campaign.

The investigation then separated recipients into three groups:

```
Recipients → Clicked → Submitted credentials
```

This distinction was important because receiving a phishing email does not indicate interaction, and clicking a phishing link does not automatically establish account compromise.

9. Message Delivery Analysis

The following KQL query was used to examine delivery activity:

```
CloudoraMsgTrace_CL
| summarize arg_max(TimeGenerated, *) by RecipientAddress
| project TimeGenerated, RecipientAddress, Campaign, SenderIP,
          SPFResult, DKIMResult, DMARCResult
```

The query keeps the most recent message for each recipient, so the number of rows equals the number of recipients targeted. Alongside the campaign and the sender IP, it returns the SPF, DKIM and DMARC results for each message.

The query returned 40 records, confirming that 40 employees were targeted by the phishing campaign.

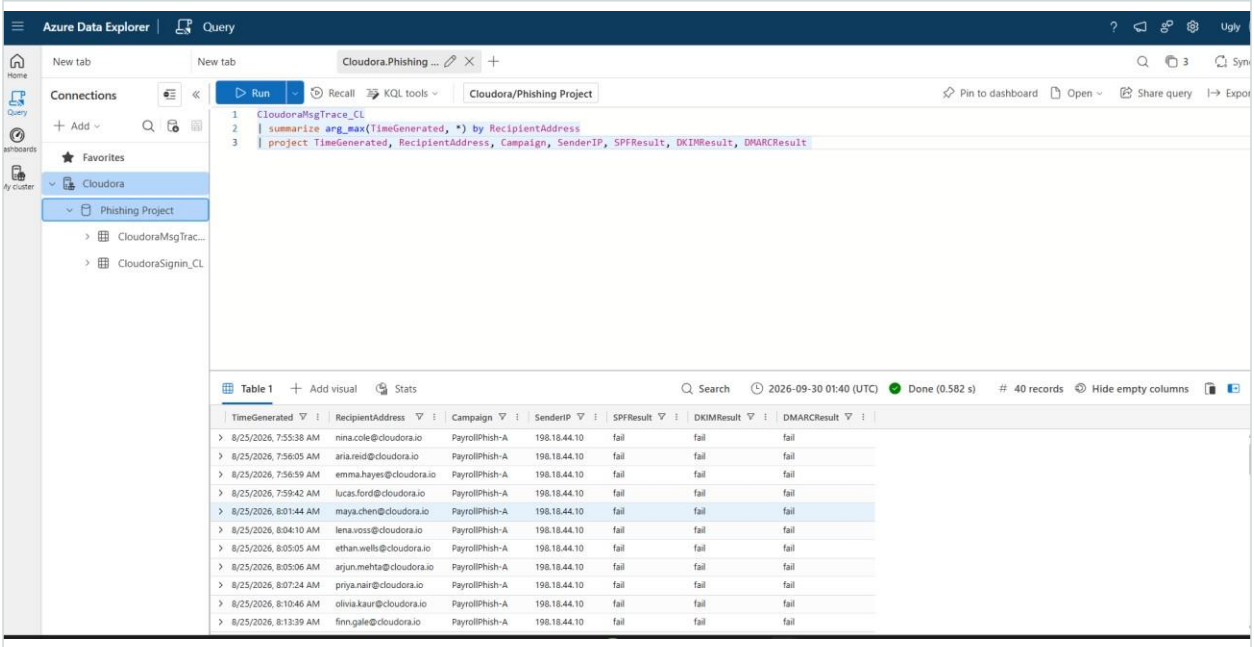


Figure 7. Message trace delivery query and results (40 records)

10. Click Analysis

The next step was to determine which recipients interacted with the phishing campaign.

```
CloudoraMsgTrace_CL
| where EventType == "Click"
| project TimeGenerated, RecipientAddress, Campaign, Url, ClickIP,
          CredentialsSubmitted
| order by TimeGenerated asc
```

The results identified six users who clicked the phishing link.

Of those six users:

- Four clicked but did not submit credentials.
- Two submitted credentials.

The two users who submitted credentials were:

- Freya
- Ryan

The four users who clicked without submitting credentials were still considered exposed and should be included in remediation and awareness follow-up.

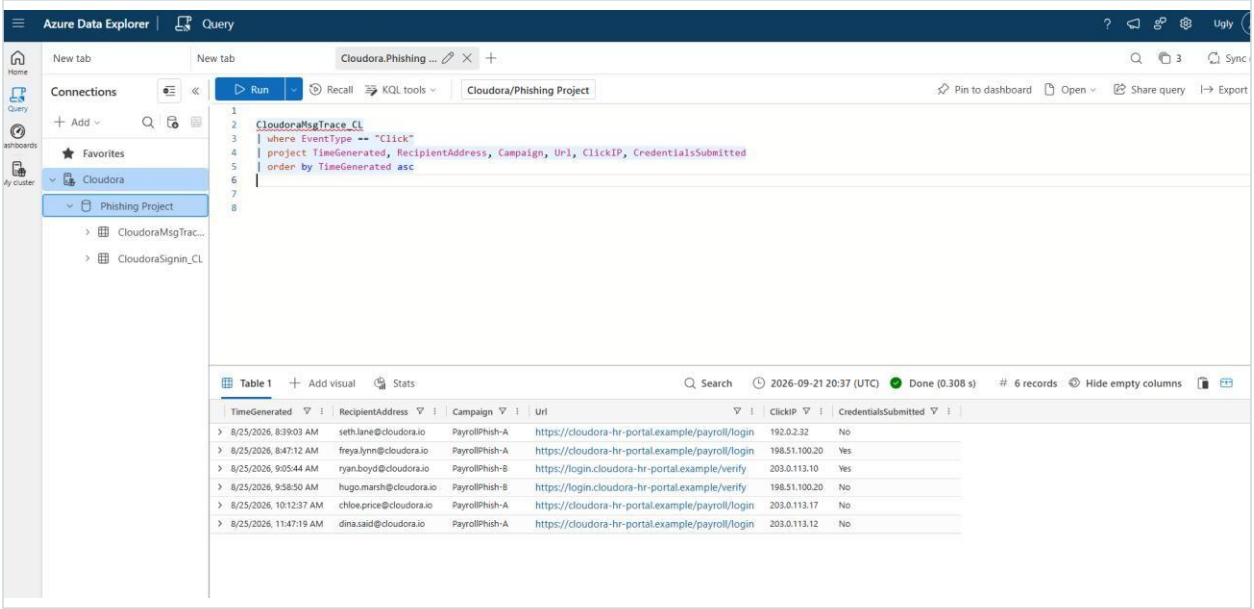


Figure 8. Click analysis query and results (6 records)

11. Credential Submission Analysis

Credential submission represented a higher level of exposure than simply clicking the phishing link.

The investigation therefore separated:

```
Click activity
```

from:

```
Credential submission
```

and finally:

```
Successful authentication
```

Freya and Ryan were identified as the two users who submitted credentials.

The next step was to determine whether those credentials were subsequently used to authenticate to Cloudora services.

12. Account Compromise Investigation

The message trace results were correlated with Microsoft Entra ID sign-in logs.

```
let CredVictims = CloudoraMsgTrace_CL
    | where EventType == "Click" and CredentialsSubmitted == "Yes"
    | distinct RecipientAddress;
CloudoraSignin_CL
| where UserPrincipalName in (CredVictims)
| where ResultType == "0"
| project TimeGenerated, UserPrincipalName, AppDisplayName, IPAddress,
          City, Country, DeviceOS, Browser
| order by UserPrincipalName asc, TimeGenerated asc
```

ResultType == "0" was used to identify successful authentication events.

This query allowed the investigation to determine whether the credentials submitted through the phishing campaign were associated with subsequent successful sign-ins. It returned nine successful sign-ins across the two accounts.

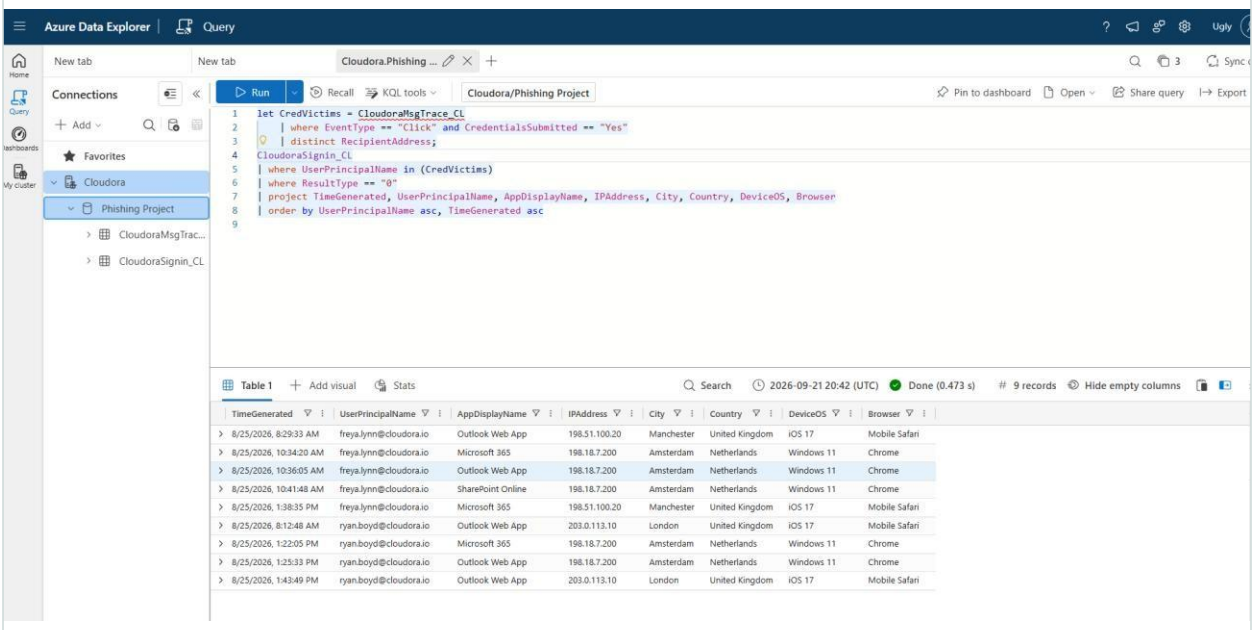


Figure 9. Successful sign-ins for the two credential victims (9 records)

13. Freya and Ryan Account Investigation

	Freya	Ryan

Normal sign-in	About 08:30, Manchester, iPhone	About 08:13, London, iPhone
Suspicious sign-in	About 10:34, Amsterdam, Windows / Chrome	About 13:22, Amsterdam, Windows / Chrome
Source IP	198.18.7.200	198.18.7.200
Apps accessed	Microsoft 365, Outlook Web App, SharePoint Online	Microsoft 365, Outlook Web App

Freya's normal activity showed a sign-in from Manchester on an iPhone at approximately 08:30 am.
A later successful sign-in occurred at approximately 10:34 am from:

```
IP: 198.18.7.200
Location: Amsterdam, Netherlands
Device: Windows
Browser: Chrome
```

The later authentication differed from Freya's known activity in several ways:

- Different geographic location
- Different device
- Different operating system
- Different browser
- Occurred after credential submission
- Originated from suspicious infrastructure

Ryan's normal activity showed a sign-in from London on an iPhone at approximately 08:13 am.

A later successful sign-in occurred at approximately 1:22 pm from the same IP address, location, device and browser that signed in to Freya's account.

The timing and characteristics of these sign-ins made them suspicious in the context of the phishing investigation.

14. Impossible Travel Analysis

Freya's sign-in sequence was consistent with an impossible travel condition.

Impossible travel is an identity security concept used when geographically distant authentication events occur within a period that would normally make physical travel between the locations unrealistic.

Freya had a normal Manchester sign-in at approximately 08:30 followed by a successful Amsterdam sign-in at approximately 10:34.

Impossible travel is an indicator rather than definitive proof of compromise because VPNs, proxies, mobile networks, and inaccurate IP geolocation can produce similar conditions.

Ryan's gap between his London sign-in at approximately 08:13 and the Amsterdam sign-in at approximately 13:22 is long enough that travel would be possible, so his account was not assessed as impossible travel. It was assessed on the other indicators below.

In both cases, the indicator was supported by several additional findings:

- Freya and Ryan submitted credentials to the phishing campaign.
- The suspicious authentication occurred after credential submission.
- The sign-ins originated from Amsterdam.
- The device and browser were unfamiliar.
- Both sign-ins came from the same source IP, which was associated with suspicious activity.

The combined evidence significantly increased the confidence that the authentication was unauthorized.

15. Attacker IP Pivot

After identifying the suspicious IP:

`198.18.7.200`

the investigation searched for other successful authentications from the same address range.

```
CloudoraSignin_CL
| where IPAddress startswith "198.18.7." and ResultType == "0"
| summarize FirstSeen = min(TimeGenerated), LastSeen = max(TimeGenerated),
            Apps = make_set(AppDisplayName)
            by UserPrincipalName, IPAddress, Country
| order by FirstSeen asc
```

The query searched the whole 198.18.7.x range rather than the single address, so neighbouring addresses would not be missed. It returned two accounts, Freya and Ryan, both from 198.18.7.200, and no others.

This showed the attacker was only able to get access into these two accounts, which bounded the scope of the incident.

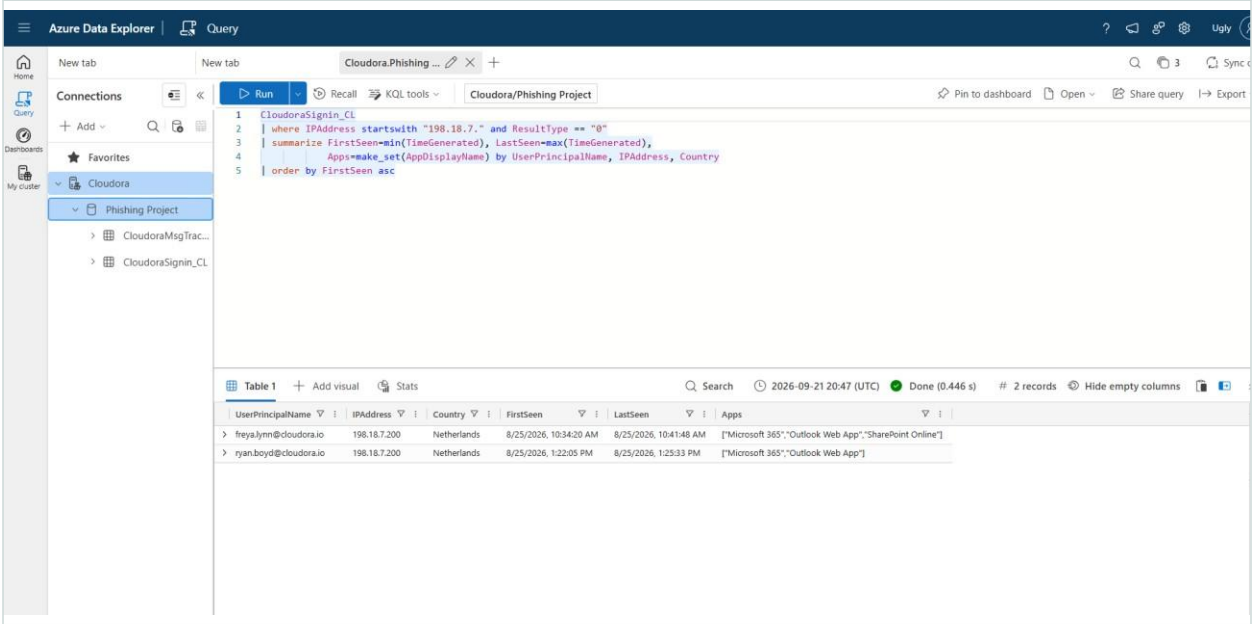


Figure 10. Attacker IP pivot results (2 records)

16. Timeline, IOCs and MITRE Mapping

The full incident timeline, indicators of compromise, MITRE ATT&CK mapping, response actions and recommendations are in the incident report (CLD-IR-0002), so they are not repeated here. The infrastructure found during email analysis is listed in section 6, and the suspicious sign-in details are in section 13.

17. Containment and Eradication

Once credential exposure and suspicious authentication were identified, the following actions were recommended.

17.1 Revoke Sessions

Active sessions and refresh tokens for affected users should be revoked.

This helps prevent an attacker from continuing to use an existing authenticated session.

17.2 Reset Credentials

Credentials for affected users should be reset.

This removes the usefulness of passwords that may have been captured through the phishing page.

17.3 Review and Re-register MFA

MFA should be enforced for affected users and existing MFA registrations should be reviewed.

Where required, MFA registration should be re-established. Both accounts were compromised with a password alone, so MFA would prevent a harvested password from being enough next time.

17.4 Block Campaign Infrastructure

The identified phishing infrastructure should be blocked where appropriate:

- 198.18.44.10
- 198.18.44.23
- 198.18.51.7
- 198.18.7.200
- cloudora-hr-portal.example (all subdomains)

Controls may include email filtering, URL filtering, DNS controls, firewall rules, and identity-based conditional access.

17.5 Purge Phishing Messages

The phishing emails should be removed from affected mailboxes using the organization's available mail security controls.

This reduces the possibility of additional users interacting with the campaign after detection.

18. Verification After Containment

Containment should be followed by additional searches to verify that the attacker is no longer active.

The investigation should check for:

- Successful sign-ins from 198.18.7.200
- New suspicious IP addresses
- New unfamiliar devices
- Additional geographic anomalies
- Additional affected accounts
- Further messages from the phishing infrastructure
- New variants of the phishing campaign
- New MFA registrations
- Suspicious activity on affected accounts

The same KQL queries used during the investigation can be rerun after containment to identify continued activity.

A successful containment process should result in no further suspicious activity associated with the identified infrastructure.

19. Key Findings

Finding 1: Cloudora employees were targeted by a payroll-themed phishing campaign. 40 employees were targeted.

Finding 2: The campaign attempted to impersonate Cloudora.

The emails presented Cloudora-related sender information while using a look-alike HR domain and separate infrastructure.

Finding 3: Two phishing variants were identified. Variant A

failed SPF, DKIM, and DMARC.

Variant B passed SPF, DKIM, and DMARC but remained malicious because the authenticated infrastructure did not represent legitimate Cloudora services.

Finding 4: Six users interacted with the campaign.

Six users clicked the phishing link and two, Freya and Ryan, submitted credentials.

Finding 5: Evidence indicated suspicious use of exposed credentials.

Both accounts showed a successful Amsterdam sign-in after credential submission from an unfamiliar Windows/Chrome environment: Freya at about 10:34 and Ryan at about 13:22.

Finding 6: One suspicious IP was associated with exactly two accounts.

The IP 198.18.7.200 was associated with successful authentication to Freya's and Ryan's accounts and no others.

20. Lessons Learned

20.1 Authentication Results Require Context

SPF, DKIM, and DMARC are important email security controls, but passing authentication does not automatically make an email legitimate.

The authenticated domain and its relationship to the organization must also be evaluated.

20.2 Look-Alike Domains Remain an Effective Phishing Technique

The phishing domain resembled Cloudora's legitimate HR infrastructure.

Users should therefore be trained to inspect the complete domain rather than relying only on the organization name displayed in an email.

20.3 Credential Submission Requires Immediate Investigation

Users who submit credentials should receive immediate identity investigation and remediation.

20.4 Identity Telemetry Is Critical

Email analysis alone would not have established the full impact of this incident.

The investigation required correlation between:

```
Email → Message Trace → Credential Submission → Entra ID Sign-in
```

20.5 Infrastructure Pivots Can Expand Incident Scope

Pivoting from Freya's suspicious sign-in IP surfaced the second affected account, Ryan, and confirmed that no other accounts were involved.

This demonstrated the value of searching for shared infrastructure across users.

21. NIST Incident Response Lifecycle Mapping

Preparation

Relevant preparation capabilities included:

- Centralized email telemetry

- Entra ID sign-in logging
- Message trace
- KQL investigation capability
- MFA
- Email security controls
- Incident response procedures

Detection and Analysis

The investigation included:

- Email analysis
- Header analysis
- SPF/DKIM/DMARC analysis
- Domain analysis
- Infrastructure identification
- Threat intelligence enrichment
- Campaign scoping
- Click analysis
- Credential submission analysis
- Entra ID investigation
- Attacker IP pivot

Containment

Containment actions included:

- Session revocation
- Blocking malicious infrastructure
- Removing phishing emails
- Restricting suspicious authentication

Eradication

Eradication included:

- Credential resets
- MFA review
- Removal of phishing emails
- Blocking identified infrastructure

Recovery

Affected accounts could return to normal use after credentials were reset, sessions were revoked, MFA was reviewed, and suspicious activity was no longer observed.

Post-Incident Activity

Post-incident activities included:

- Documenting the investigation
- Preserving relevant evidence
- Reviewing detection logic
- Updating email security controls
- Improving phishing awareness
- Reviewing opportunities for additional identity protections

22. Investigation Methodology

The investigation followed a progressive evidence-correlation process.

Stage 1: Email Analysis

The raw email files were analyzed to establish the sender identity, authentication results, domains, URLs, and infrastructure.

Stage 2: Infrastructure Analysis

The look-alike domain and sending IP addresses were identified and enriched using threat intelligence.

Stage 3: Campaign Scoping

Message trace data was used to determine how many users received and interacted with the campaign.

Stage 4: Credential Exposure

Users who clicked were separated from users who submitted credentials.

Stage 5: Identity Investigation

Credential victims were correlated with successful Entra ID sign-ins.

Stage 6: Infrastructure Pivot

The suspicious authentication IP was searched across the environment to identify additional affected accounts. It returned two accounts and no others.

Stage 7: Containment and Verification

Affected accounts and infrastructure were contained, followed by additional searches to verify that suspicious activity had stopped.

23. Final Assessment

The investigation identified a payroll-themed phishing campaign targeting Cloudora employees.

The campaign used Cloudora impersonation, a look-alike HR domain, multiple sending IP addresses, and social engineering designed to create urgency around payroll.

40 employees were targeted. Six users clicked the phishing link, and two submitted credentials.

The investigation then identified suspicious successful authentication associated with both credential victims. Freya's account showed a normal Manchester sign-in followed approximately two hours later by a successful Amsterdam sign-in from an unfamiliar Windows/Chrome environment. Ryan's account showed a normal London sign-in followed by a successful sign-in at about 13:22 from the same Amsterdam IP, device and browser.

The suspicious source IP, 198.18.7.200, was associated with successful authentication to these two accounts and no others.

The investigation therefore established a progression from:

```
Phishing delivery → User interaction → Credential exposure → Suspicious authentication →
Two affected accounts
```

The investigation demonstrates the importance of correlating email, messaging, threat intelligence, and identity telemetry rather than relying on a single indicator.

This investigation covered delivery, user interaction, credential exposure and sign-in activity.